die Mobiliar

Zero «implicit» Trust

Die Mobiliar auf den Weg zu Zero Trust

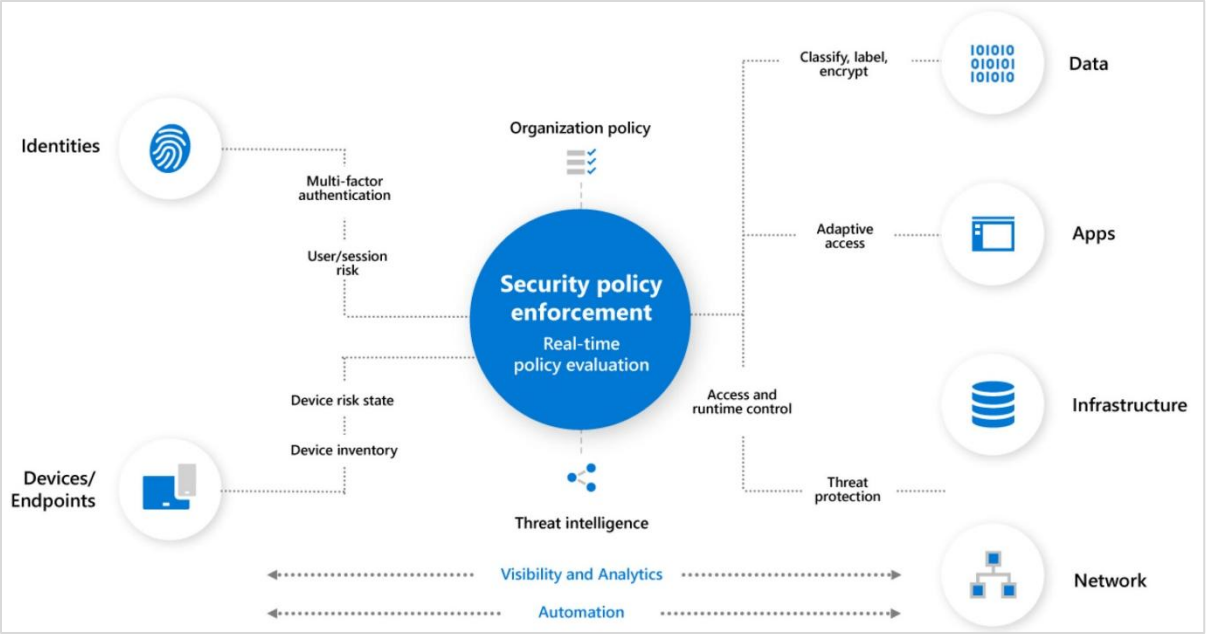
Davide Cavadini, Leiter Cyber/IS/IT Sicherheitsarchitektur

Was ist Zero Trust?

Zero Trust ist mehr als ein Konzept – es ist eine Philosophie

"Zero trust (ZT) provides a **collection of concepts** and ideas designed to minimize uncertainty in **enforcing accurate, least privilege per-request access decisions** in information systems and services in the face of a **network viewed as compromised**." – NIST SP 800-207

- Zero Trust bringt einen Paradigmenwechsel mit sich. In einer Zero Trust Architektur wird auch Objekten innerhalb des Perimeters **kein inhärentes Vertrauen** mehr entgegengebracht. Ziel ist das Aufheben von Vertrauensbeziehungen, die nur darauf basieren, dass etwas "innen" ist. Das heisst sämtliche Subjekte, Assets und Workflows gelten erstmals als nicht vertrauenswürdig und müssen sich das Vertrauen erarbeiten ("implicit trust").
- Mit Zero Trust werden **nur bedingt neue Konzepte** eingeführt, sondern vieles basiert auf bestehenden Konzepten, die aber wesentlich konsequenter angewendet werden.
- Zero Trust ist **kein Produkt**, sondern ein **dynamisches datenzentriertes Sicherheitsmodell**. Der Zugriff lässt sich dynamisch je nach Benutzeridentität, Standort, Gerätetyp und anderen Faktoren anpassen.



https://hackernoon.com/zero-trust-architecture-an-introduction-sw1q37na

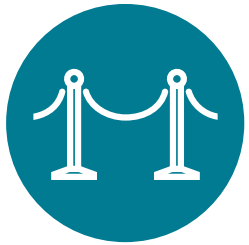
Zero Trust Principles

Assume Breach

- Organisations should always assume that there is a attacker in their environment and implement security controls to minimise the impact.

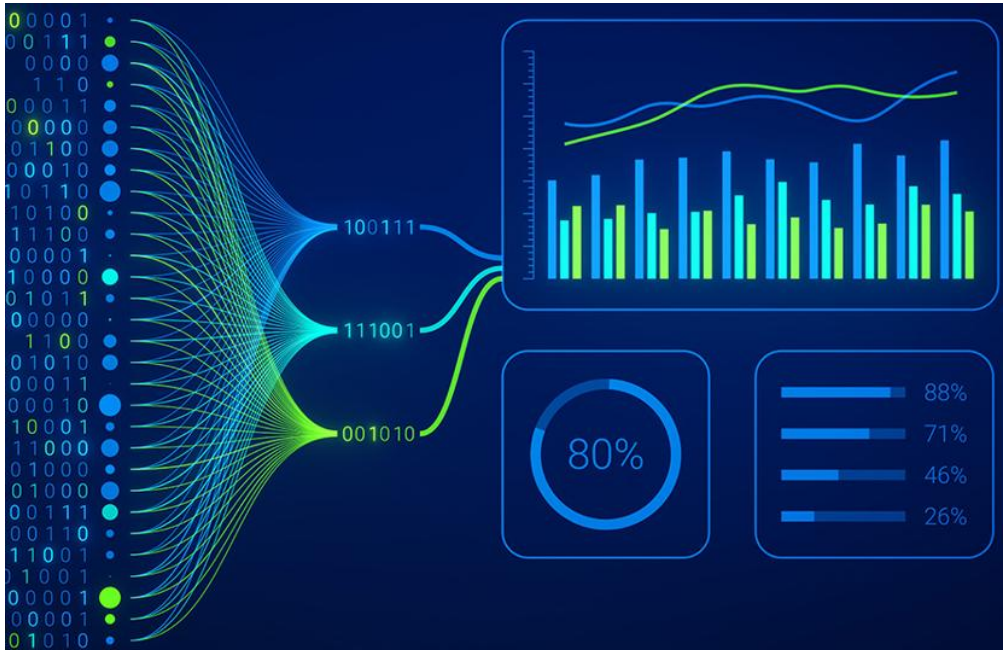
Never Trust, Always Verify

- Don’t give implicit trust: Organizations should continually review all access requests to make sure they haven’t been compromised.



Least Privilege Access

- Users, devices and services should be granted the minimum access necessary to perform their function and for the shortest possible period of time.



Warum ist es wichtig?

Warum braucht es einen Paradigmenwechsel in der Cybersicherheit?

Digitalisierung und Cloud Transformation

- Digitalisierung verändert die Wertschöpfungskette von Unternehmen. Die Interaktion mit Kunden oder Partnern hat sich verändert. Dies führt zu einem immer grösseren Angriffsfeld. Diese neuen Herausforderungen zwingen ein Umdenken traditioneller Sicherheitsmodelle.

Schäden eines erfolgreichen Angriffs verhindern / verringern

- Reduzierung des Blast Radius
- Reputationsschaden in den Griff bekommen

Proaktive Erfüllung regulatorischer Anforderungen

- Vorschriften erfordern strenge Datenschutz- und Managementkontrollen
- bessere Sichtbarkeit und Schutz
- Einfacheres Audit Ihrer Umgebung

Aktuelle Herausforderungen für die Mobiliar

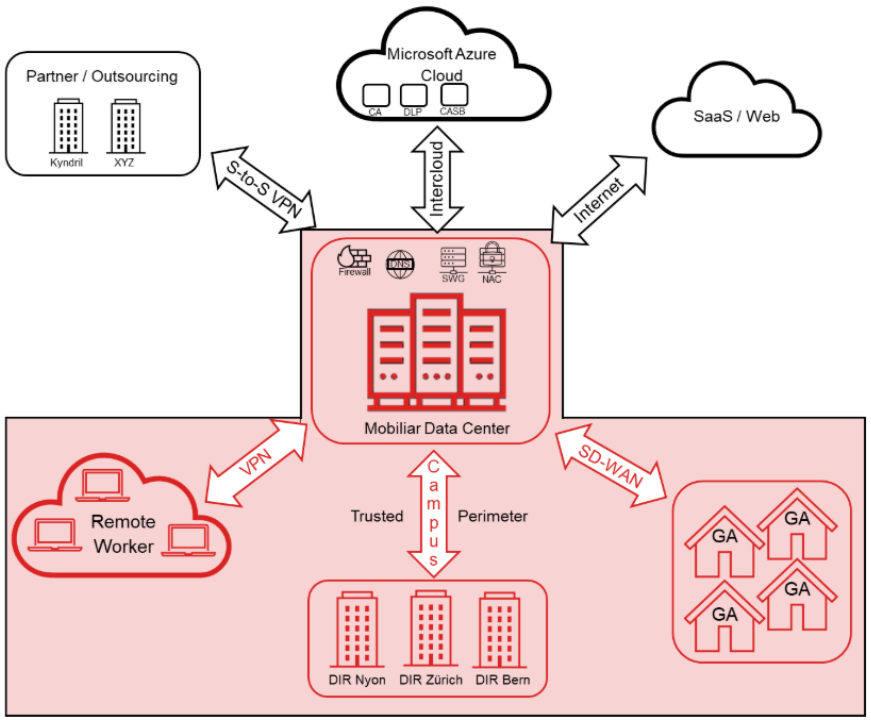
Die Corporate IT befindet sich im Umbruch:
Durch die Cloud-Strategie werden On-Premise-Lösungen kontinuierlich abgelöst bzw. modernisiert.

Der Betrieb eigener Datacenter ist strategisch unerwünscht und wird in Zukunft nicht mehr wirtschaftlich sein. Die Ära eigener Datacenter, wie wir sie heute kennen, neigt sich dem Ende zu.

Das klassische, perimetrische Sicherheitsmodell hat mit der Migration der Applikationen in die Cloud ausgedient.

Das heutige Konnektivitätskonzept – der Internet-Traffic aller Standorte wird via eigene Datacenter weitergeleitet – verliert langfristig den tragenden Baustein. Es besteht ein Modernisierungsbedarf!

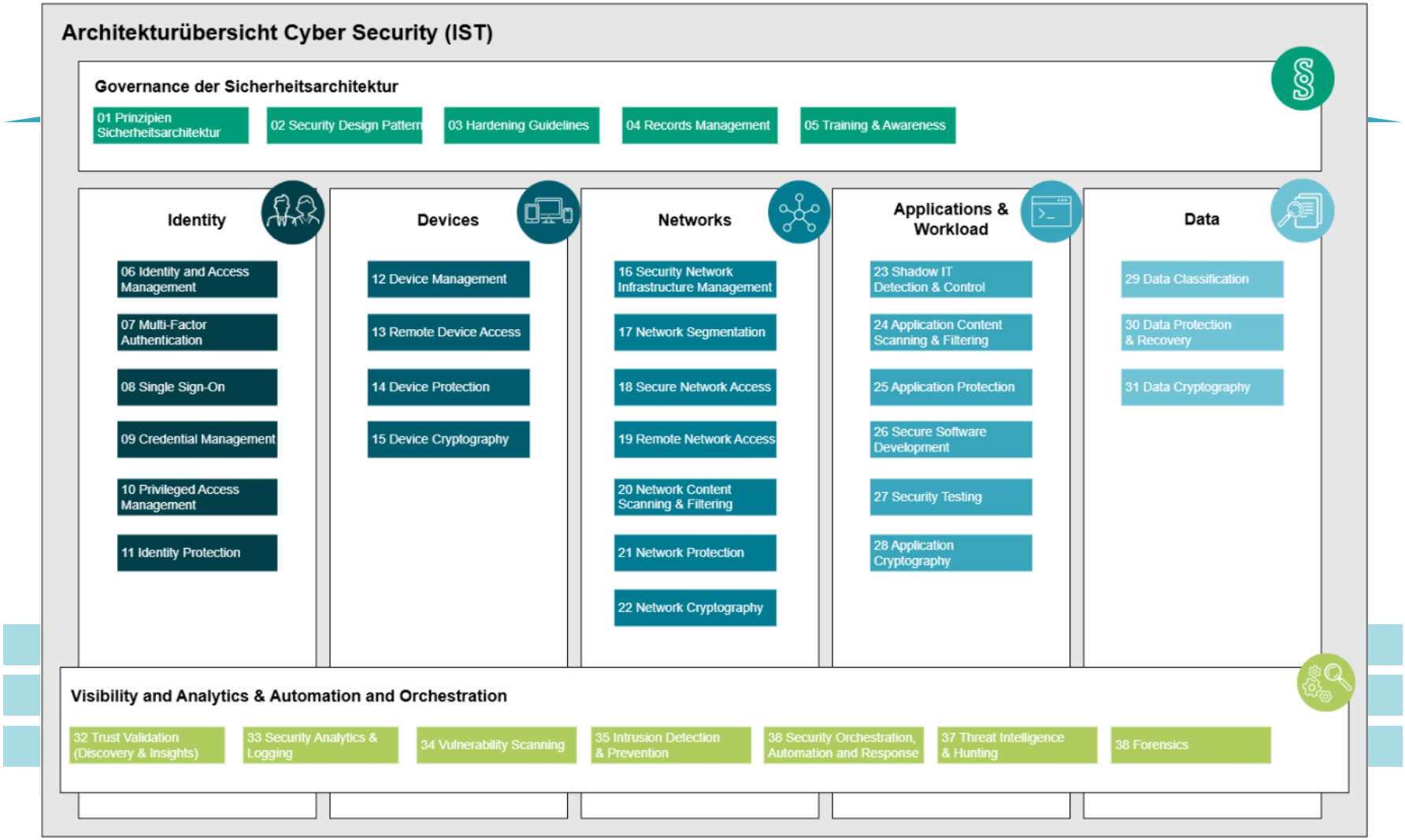
Ist-Situation



Datacenter	Eigene Datacenter dienen als Basis für die Vernetzung, Kommunikation und als Austrittspunkt für einen Grossteil des Internet-Traffics der Mobiliar.
Perimeter	Zonenarchitektur mit geschütztem Perimeter, der hohes Vertrauen geniesst.
Direktionsstandorte	Angebunden mittels Campus-Netzwerk und als Teilnehmer in den Perimeter integriert.
GAs und andere Standorte	Angebunden mittels Swisscom SD-WAN und als Teilnehmer in den Perimeter integriert.
Remote Worker	Angebunden mittels VPN und als Teilnehmer in den Perimeter integriert.
Partner / Outsourcing	Punktuell mittels Site-to-Site-VPN (S2S-VPN) angebunden und als Teilnehmer in den Perimeter integriert.
Primäre Cloud-Provider (Microsoft Azure)	Durch eine dedizierte Verbindung mit hoher Qualität (SLA) an die Datacenter angebunden und Teil des Perimeters.
SaaS, Web, etc.	Zugriff über zentralisierte Egress-Infrastruktur (SWG Proxy, CASB) auf das Internet.

Zero Trust Fachliches und logisches Modell

Fachliches Modell – Zeigt die fachlichen Fähigkeiten einer Zero Trust Architektur für einen ganzheitlichen Schutz der Unternehmensressourcen



TRADITIONAL | INITIAL | ADVANCED | OPTIMAL

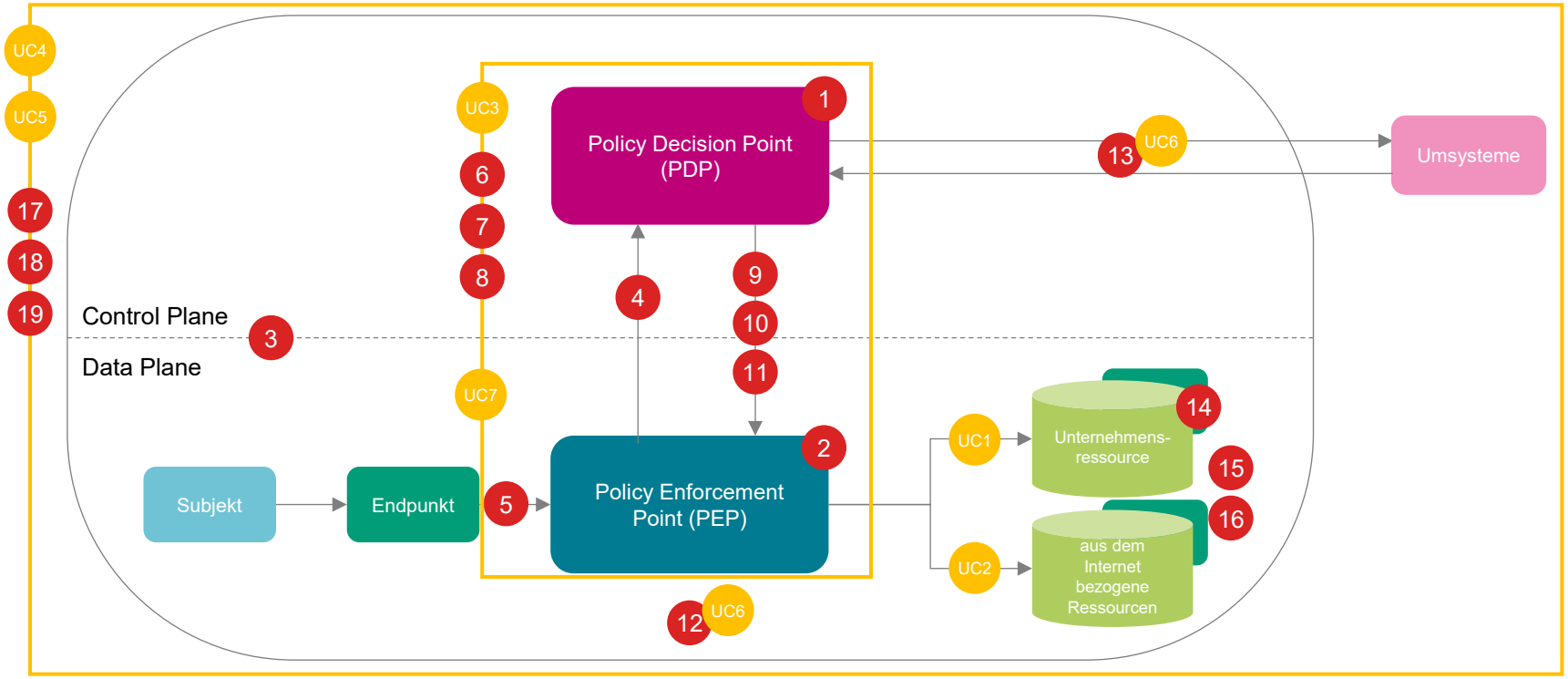
ZT-Modell von CISA

Das Zero Trust Maturity Modell von CISA basiert auf fünf Pilllars und drei übergreifenden Fähigkeiten.

Jede Pillar unterteilt sich in verschiedene Functions.

Die Maturität kann je Pillar unterschiedlich ausfallen und entwickelt sich dynamisch über die Zeit hinweg.

Logisches Modell – Strukturierung des "Systems" und dessen funktionale bzw. nicht-funktionale Beschreibung mittels Anforderungen



Die Beschreibungen der Use Cases finden sich im Wiki.

- UC1: Sicherer Zugriff auf durch die Mobiliar bereitgestellte Unternehmensressourcen
- UC2: Sicherer Zugriff auf aus dem Internet bezogene Ressourcen
- UC3: Durchsetzung einer strengen Zugriffskontrolle
- UC4: Verhinderung von Lateral Movement
- UC5: Verhinderung von Datenabfluss
- UC6: Unternehmensweites Monitoring und Nutzung der Daten
- UC7: Administrative Zugriffe

Die Beschreibungen der Anforderungen finden sich im Wiki.

PDP – Komponente, welche die Entscheidungen über Zugriff auf Ressourcen basierend auf definierten Sicherheitsrichtlinien trifft.

PEP – Komponente, die die Entscheidungen des PDPs umsetzt, indem sie den Zugriff auf Ressourcen kontrolliert und durchsetzt.

Subjekt – Entität, welche auf eine Ressource zugreifen will. Dies kann sowohl menschliche Benutzer als auch nicht-menschliche Entitäten umfassen.

- Mitarbeitende
- Partner
- Gäste
- Geräte
- Anwendungen
- Automatisierte Prozesse

Endpunkt – Gerät oder System, mit welchem das Subjekt auf eine Ressource zugreifen will bzw. auf welchem eine Ressource gehostet ist.

- Clients (managed und unmanaged)
- Server
- Virtuelle Maschinen und Container

Ressource – Ziele, auf die ein Subjekt zugreifen will.

- Daten
- Anwendungen
- Dienste
- Infrastruktur

Umsystem – Systeme, die mit PDPs oder PEPs interagieren und wichtige Kontextinformationen für die Entscheidungsfindung liefern.

- Interne Anwendungen oder Dienste (z.B. IAM, SIEM, Behavior Analytics)
- Externe Anwendungen oder Dienste (z.B. SaaS)

"Nur wer sein Ziel kennt, findet den Weg."

Laotse

Nächste Schritte zur Umsetzung des Zero Trust Zielbild

NIST SP 1800-35 "Implementing a Zero Trust Architecture – Project documentation"

- NIST beschreibt im Dokument 1800-35 verschiedene Phase bei der Umsetzung einer Zero Trust Architektur:
  1. Enhanced Identity Governance "crawl phase" (ohne Cloud-Fähigkeiten)
  ⇩
  2. EIG run phase (mit Cloud-Fähigkeiten)
  ⇩
  3. Microsegmentation
  ⇩
  4. SDP (Software-Designed Perimeter)
  ⇩
  5. SASE (Secure Access Service Edge)

- Die Phasen bauen aufeinander auf und sind in Builds unterteilt mit konkreten Umsetzungsbeispiele für 4 fiktiven Unternehmen mit unterschiedlichen Ausgangsarchitekturen

Wie weiter – next Step Richtung Zero Trust

- Aktuelle Herausforderungen + aktuelle Maturität nach CISA + Phasen gemäss NIST SP 1800-35

TRADITIONAL | INITIAL

ADVANCED | OPTIMAL

1. Enhanced Identity Governance "crawl phase" (ohne Cloud-Fähigkeiten)
2. EIG run phase (mit Cloud-Fähigkeiten)
3. Microsegmentation
4. SDP (Software-Designed Perimeter)
5. SASE (Secure Access Service Edge)

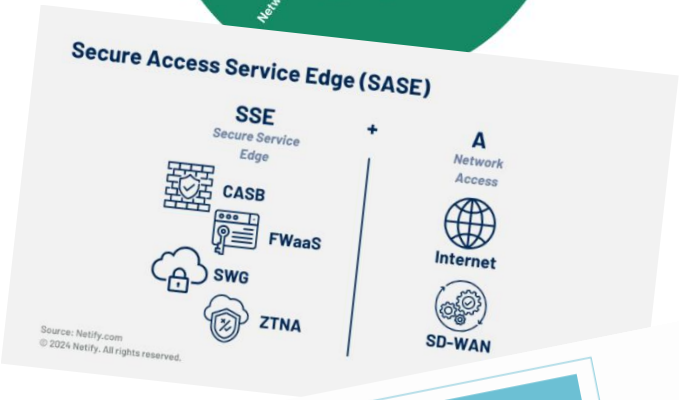
SASE / SSE

Begriffsdefinition SASE / SSE

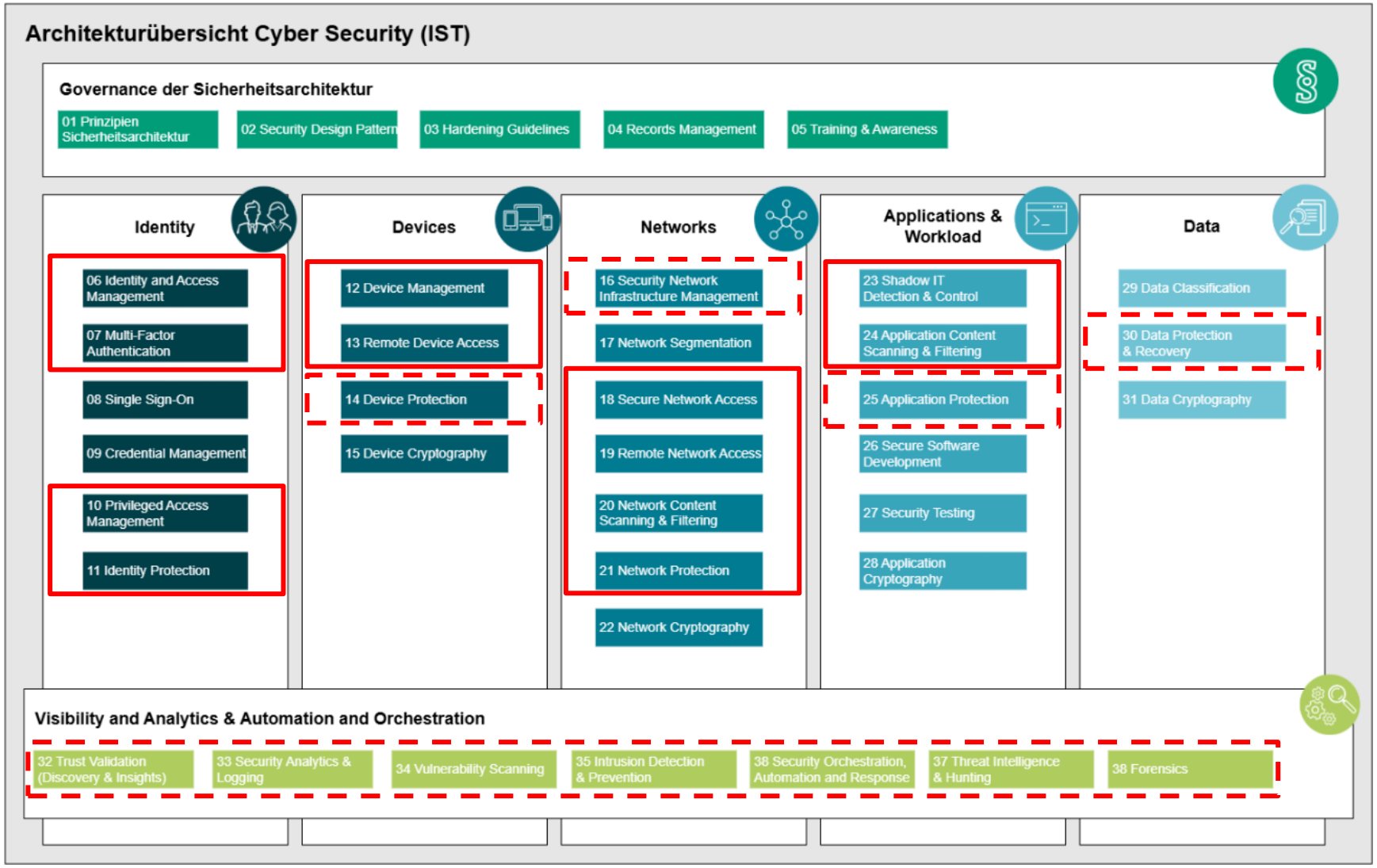
- **Secure Access Service Edge – SASE** stellt die Konvergenz von Netzwerk und Sicherheitsfunktionen in einem einzigen cloudnative Service dar.

Netzwerkfunktionen SASE	Sicherheitsfunktionen SASE
• SD-WAN • WAN Optimierung • Quality of Service	• ZTNA – Zero trust Network Access • SWG - Secure Web Gateway • CASB – Cloud Access Security Broker • FWaaS – Firewal as a Service

- **Secure Service Edge – SSE** konzentriert sich auf die reine Sicherheitsfunktionen und stellt diese als cloudnative Service zur Verfügung.



Einbettung / Einfluss von SASE auf die Cyber Security Architektur



SASE in der Architekturübersicht Cyber Security

Die Architekturübersicht Cyber Security basiert auf dem Zero Trust Maturity Modell von CISA. Die Mobiliar verwendet dieses als funktionales Modell für ihre Zero Trust Architektur.

Rot hinterlegt sind die Sicherheitsmechanismen, die durch die SASE-Technologie adressiert werden

Legende:

- Sicherheitsmechanismen mit direktem Einfluss durch SASE / SSE
- Sicherheitsmechanismen mit partiellem Einfluss durch SASE / SSE

die Mobiliar

Zielbild mit SASE

Partner & Outsourcing
Mainframe
...

Preferred Cloud Provider
CA
DNS
Firewal
DLP

SaaS & Web

Dedicated Link

Internet

Internet

CASB
SWG
ZTNA
SASE Hub
FWaaS
DLP
RBI

Internet

SDN

SDN

Mobiliar Clients

GA
GA
GA
GA

DIR Nyon
DIR Zürich
DIR Bern

Nicht im Einflussbereich von SASE

Fragen / Diskussion